

UnifiedGarage — Technical Brief

A modern Dealer Management System built as a single multi-tenant SaaS. Replaces the legacy stack most dealers carry today (Reynolds & Reynolds, CDK Global, Dealertrack) plus a pile of bolt-ons (separate F&I menu, separate desking tool, separate appraisal form, etc.) with one platform that actually talks to itself.

Stack

Backend	NestJS 10 (TypeScript), Prisma 5, PostgreSQL on Supabase, deployed on Railway. ~200 REST routes under <code>/api/v1/*</code> . Swagger gated by env in non-prod.
Frontend	Next.js 16 (App Router), React 19, Turbopack, Tailwind v4, Inter font. Deployed on Vercel at <code>app.unifiedgarage.com</code> .
Marketing	Static HTML/CSS on Vercel at <code>unifiedgarage.com</code> .
Storage	AWS S3 with presigned uploads for vehicle photos + documents.
Email	Resend. SMS: Twilio with inbound webhook.
Payments	Stripe subscriptions for the SaaS plan + Stripe Connect for customer-portal RO payments.
Jobs	pg-boss (Postgres-native queue, no separate Redis).
Observability	Sentry with 5xx-only forwarding from a global exception filter; pino structured NDJSON logs with secret redaction; PostHog for product analytics.

Auth & security

- **JWT access** (15-min) + **opaque refresh** (30-day) stored as httpOnly cookies (`ug_refresh` , scoped to `/api/v1/auth` , SameSite=None+Secure in prod).
- **Bcrypt** password hashing with a lazy-upgrade path from a legacy SHA-256 scheme so old hashes self-heal on next successful login.

- **TOTP MFA** (RFC 6238) with recovery codes. Mandatory enrollment within 7 days for `SUPER_ADMIN` / `DEALER_ADMIN` / `FINANCE_MANAGER` , enforced by `MfaEnforcementGuard` .
- **Account lockout** with escalating durations (15→30→60-min cap) and user-enumeration-resistant error responses.
- **Rate limiting** via `@nestjs/throttler` : 10/min on auth endpoints, 100/min global default.
- **Double-submit cookie CSRF** on every mutating endpoint. `X-CSRF-Token` header validated against `ug_csrf` cookie with constant-time comparison; bootstrap, webhook, and public paths exempt.
- **CORS** explicit allowlist (no wildcards), `credentials: true` . **Secret redaction** baked into `pino` (`password` , `passwordHash` , `authorization`).

Data model

- **66 Prisma models**. Multi-tenant via a `dealershipId` foreign key on every business model.
- **9 user roles**: `SUPER_ADMIN` , `DEALER_ADMIN` , `MANAGER` , `SALES_REP` , `FINANCE_MANAGER` , `SERVICE_ADVISOR` , `TECHNICIAN` , `PARTS_CLERK` , `ACCOUNTING` . Role policy is a single source of truth in `lib/rolePolicy.ts` on the frontend, mirrored by `src/auth/role-policy.ts` on the backend.
- **Multi-rooftop** via `DealerGroup` + `storeLocationId` on users and inventory, for franchise groups.

Modules

SALES PIPELINE

Leads → Deals (worksheet + desking) → F&I (menu selling + e-sign) → Funded → posted to GL automatically. Lead capture via `/leads/capture/:dealershipId` , round-robin assignment, SLA tracking, conversion to deal-and-customer in one call.

INVENTORY & RECON

Vehicle CRUD with photos, VIN decode, market-based pricing, recon workflow (`LANDED` → `RECON` → `READY` → `SOLD`). Bulk operations for status / pricing / archive. Aging alerts.

SERVICE

Repair orders with PBS/Tekion-style intake fields: `fuelLevelIn` , `keyTag` , `appointmentSource` enum, `transportation` enum, `insuranceClaim` , `deductibleAmount` . Per-line job types (`CUSTOMER_PAY` / `WARRANTY` / `INTERNAL` / `FLEET`), per-line status codes (`A` Active / `B` Billed / `C` Complete / `HP` Hold-Parts / `HT` Hold-Tech / `HA` Hold-Approval). Time clock per (tech, line) session — productivity report compares actual hours vs flat-rate allowed hours. Multi-point inspections with photos, dispatch board, capacity by `ServiceBay` .

PARTS

Stock + on-order + reorder points + min stock. Purchase orders with receiving workflow. Special orders linked to RO lines. Stock adjustments with reason codes (`PURCHASE` , `SALE` , `RETURN` , `DAMAGED` , `COUNT_CORRECTION` , `TRANSFER`).

F&I

Providers, products with rate decks (term × mileage × deductible × coverage level matching), menu builder with tier pricing. Deal-attached F&I items, decline tracking with full audit trail, e-sign packages with signed PDF generation. Reports: PVR, penetration, gross by product, gross by manager.

ACCOUNTING

Chart of accounts (default Canadian-GAAP-ish for dealerships, customizable per rooftop). Pure journal-entry generators in `src/accounting/je-generator.ts` for deal contracted, F&I item accepted, RO invoiced, payment received. Every JE is balance-checked before persistence ($\Sigma\text{debit} = \Sigma\text{credit}$, half-cent tolerance). CSV + IIF export, QuickBooks Online OAuth + per-entry push.

CUSTOMER PORTAL

Separate auth flow at `/portal/auth/*` for retail customers. View their vehicles, service history, documents, book appointments, pay ROs via Stripe Connect, e-sign F&I packages.

NOTIFICATIONS

Templated email + SMS triggers on RO status change, appointment reminders, recall campaigns. Suppression list, quiet hours, customer portal preferences, Twilio inbound webhook for replies. Cron jobs for time-based sends (appointment reminders, service-due).

REPORTING + DASHBOARDS

Deal/inventory/service/parts/customer summaries, sales trend, inventory aging, sales by rep, lead conversion funnel, KPI rollup. Group-level dashboards for dealer-group `SUPER_ADMIN` .

Frontend architecture

- App Router with a role-protected layout (`DmsLayout`) that waits for zustand-persisted auth to hydrate before rendering, to avoid bouncing signed-in users to `/login` on hard refresh.
- Horizontal `TopNav` with 7 grouped entries (Dashboard, Sales, Inventory, Service, F&I, Insights, Settings) and dropdowns. Each entry hidden by role via `canAccess(role, navKey)` .
- Shared `PageHeader` + `StatRow` components establish a consistent rhythm across 15+ primary screens — small uppercase amber eyebrow, big tracking-tight headline, prose lead, dark action button, thin-divider typographic stats. No icon-tile cards.

- Axios instances per module (`inventoryApi` , `dealsApi` , etc.) with `withCredentials: true` , automatic refresh-on-401 with single-flight coalescing, and an X-CSRF-Token interceptor.

Testing & CI

- **Backend:** Jest with `notifications.spec.ts` , `je-generator.spec.ts` (22 tests across all 4 JE generators + balance invariant), `csrf.spec.ts` (26 tests on the guard). 57 passing.
- **Frontend:** Vitest unit tests for `dealCalc` , `worksheetCalc` , `rolePolicy` plus a Playwright e2e smoke (login renders, protected route redirects).
- **GitHub Actions** runs lint + typecheck + build + tests on every PR; the e2e job spins up Chromium and runs Playwright.
- 100% TypeScript on both sides. `next.config.ts` has `ignoreBuildErrors: false` — the build fails on type errors so they can't ship silently.

Operations

- Railway runs `prisma migrate deploy` before boot via `startup.js` (with a 2-minute timeout and a fail-soft fallback so a migration glitch can't 502 the whole API). Supabase pooler workaround handled via `directUrl` in `schema.prisma` (migrations use a direct :5432 connection; runtime uses pgBouncer at :6543).
- Sentry releases tag with `RAILWAY_GIT_COMMIT_SHA` / `VERCEL_GIT_COMMIT_SHA` automatically so any error has a 1:1 link to the commit that introduced it.
- `JOBS_DISABLED=1` env opts the pg-boss runtime out for local dev without a queue.
- `npm run db:seed` runs the same seed logic prod uses (bcrypt admin user, default dealership) idempotently — safe to re-run anytime.

Repo layout

my-dms/ src/auth/ src/inventory/ src/deals/ src/fi/ src/service/ src/accounting/ src/portal/ prisma/schema.prisma prisma/seed.js	NestJS backend JWT, MFA, CSRF, logout, password hashing Vehicle CRUD, photos, bulk ops Worksheet, desking Provider/product/menu/rate, deal items, packages ROs, lines, parts, inspections, capacity, time clock COA, journal entries, exports, QBO Customer-facing endpoints 66 models Idempotent seed (bcrypt admin user)
my-dms-frontend/ app/ components/TopNav.tsx components/PageHeader.tsx components/DmsLayout.tsx	Next.js frontend Routes (App Router) Primary nav Shared header + StatRow Protected-route gate

lib/api.ts	Axios + refresh coordination + CSRF
lib/rolePolicy.ts	Role/permission single source of truth
unifiedgarage-marketing/	Static landing page (HTML/CSS only)

Deployment URLs

- API: <https://api.unifiedgarage.com> (Railway)
- App: <https://app.unifiedgarage.com> (Vercel)
- Marketing: <https://unifiedgarage.com> (Vercel)
- Status: not yet wired (planned)

What's deliberately out of scope

- Direct lender integrations (RouteOne, Dealertrack lender portal). Will require contracts that need volume.
- Inventory syndication outbound to Autotrader, Cars.com, CarGurus, Facebook Marketplace.
- OEM portal integrations (factory warranty, PDI).
- Native mobile apps (the web app is responsive; native is a future Capacitor wrapper, not a rewrite).
- SOC 2 / GLBA Safeguards Rule compliance audit (informally meets most controls; not yet certified).